

דוח פרויקט מסכם: פיתוח מערכת שליטה
מרחוק (RAT) מוסווית
קורס: פייתון התקפי (Offensive Python)
מגיש: heikel muhammad
שם הכלי: Tactical Shadow RAT

1. מבוא וסקירת המערכת

במסגרת פרויקט הגמר, פותח כלי שליטה מרחוק (Remote Access Trojan) מורכב, המשלב יכולות איסוף מודיעין, שליטה במערכת הקבצים והסוואת מטען ייעודי (Payload). המערכת נבנתה בארכיטקטורת Client-Server על גבי פרוטוקול TCP, תוך דגש על עקיפת מנגנוני הגנה (AV/IDS) ויציבות תקשורתית מקסימלית.

2. פירוט טכני ועמידה בדרישות המטלה

המערכת נבנתה בדיוק לפי דרישות המרצה, תוך יישום הטכנולוגיות הבאות:

ממשק הניהול נבנה: (צד התוקף) GUI
הוא כולל חלון לוגים Tkinter. באמצעות ספריית

דינמי המציג פלט מהקורבן בזמן אמת, כפתורי שליטה מהירים להפעלת הכלים השונים, ושורת פקודה אינטראקטיבית.

פרוטוקול תקשורת (TCP): בחרתי לעבוד מעל Sockets בתקן TCP כדי להבטיח העברת נתונים אמינה (Reliable) ולמנוע איבוד מידע בעת שליחת קבצים כבדים כמו צילומי מסך.

הצפנת תעבורה (Obfuscation): כל המידע העובר ברשת (הודעות JSON) מוצפן באמצעות אלגוריתם XOR סימטרי. מנגנון זה מבטיח שחתימות התקשורת יהיו שונות בכל פעם, מה שמקשה על מערכות ניטור רשת לזהות את הפקודות.

חוסן ויציבות (Persistence): המערכת כוללת מנגנון Auto-Reconnect. צד הנתקף מתוכנת לנסות ולהתחבר מחדש לשרת במידה והחיבור נותק (ריסטארט למחשב או נפילת רשת), ובכך נמנעת קריסת הכלי.

3. כלים התקפיים שהוטמעו (Capabilities) במערכת שולבו כלים מתקדמים המאפשרים שליטה מלאה:

רישום והקלטת הקשות מקלדת: Keylogger
בזמן אמת לשם גניבת סיסמאות ומידע רגיש

(CMD) הרצת פקודות מערכת: Remote Shell
וקבלת פלט מלא ישירות לממשק התוקף

יכולת ללכוד את: Screenshots (צילום מסך)
מסך הקורבן בכל רגע נתון, קידוד התמונה
ושליחתה לשרת להצגה ויזואלית Base64-ב
GUI-ב

4. הכלי החדש (למידה עצמית): File
Hashing (SHA-256)
כחלק מהדרישה ללמידה עצמית, הטמעת
מנגנון גיבוב (Hashing) מתקדם מבוסס
אלגוריתם SHA-256.

הצורך: בעולם הפייתון ההתקפי, שמות קבצים הם חסרי משמעות מכיוון שניתן לשנותם בקלות.

היישום: הכלי מחשב "טביעת אצבע דיגיטלית" ייחודית לכל קובץ במחשב הנתקף. זה מאפשר לתוקף:

זיהוי קבצים רגילים: זיהוי קבצי סיסמאות או קונפיגורציה לפי התוכן שלהם, גם אם שונה שמם.

אימות שלמות (Integrity): לוודא שקובץ הלוגים (logs.txt) לא זוהה או שונה על ידי מנגנוני הגנה מקומיים.

5. אריזה כסוס טרויאני (Trojan Implementation)
השלב הסופי של הפרויקט היה הפיכת הקוד לסוס טרויאני אמיתי:

הקובץ אוחד עם תמונת SFX Image Binding:

לגיטימית JPEG.

Infiltration: בעת ההפעלה, המשתמש רואה את התמונה נפתחת באמצעות מציג התמונות RAT-בעוד שקוד ה Windows המקורי של מחולץ לתיקייה זמנית ומתחיל לפעול CMD שקט ללא חלון Background Process-כ נראה לעין.

6. סיכום

הפרויקט מדגים שילוב של הנדסה חברתית, קריפטוגרפיה ותכנות התקפי מתקדם. המערכת עומדת בכל דרישות הקורס ומספקת פתרון שליטה חזק, מוצפן ובלתי נראה לנתקף.